



GenAI SECURITY
PROJECT

AIUC-1: Crosswalks OWASP Top 10 For Agentic Applications

Agentic Security Initiative

Version 1.0
May 2026



The information provided in this document does not, and is not intended to, constitute legal advice. All information is for general informational purposes only. This document contains links to other third-party websites. Such links are only for convenience and OWASP does not recommend or endorse the contents of the third-party sites.

License and Usage

This document is licensed under Creative Commons, CC BY-SA 4.0

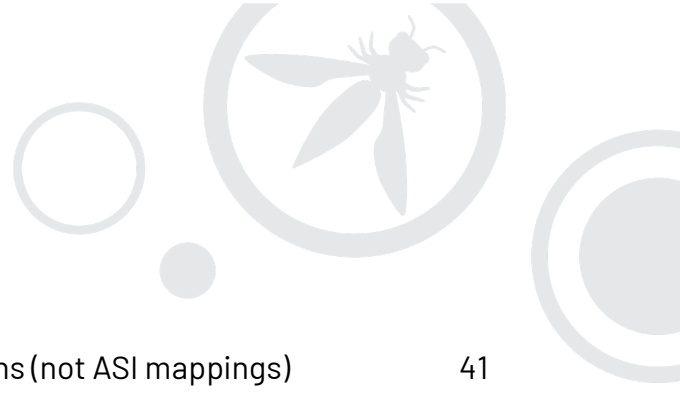
You are free to:

- Share — copy and redistribute the material in any medium or format
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.
- Under the following terms:
 - Attribution — You must give appropriate credit, provide a link to the license, and indicate if changes were made. You may do so in any reasonable manner but not in any way that suggests the licensor endorses you or your use.
 - Attribution Guidelines - must include the project name as well as the name of the asset Referenced
 - OWASP Top 10 for LLMs - GenAI Red Teaming Guide
- ShareAlike — If you remix, transform, or build upon the material, you must distribute your contributions under the same license as the original.

Link to full license text: <https://creativecommons.org/licenses/by-sa/4.0/legalcode>

Table of Content

Introduction	5
Document structure	5
Mapping methodology	6
Transparency note	6
Scope note	7
Summary of Strategic Gaps	7
Part A - AIUC-1 Requirements -> OWASP Agentic Top 10	8
A. Data & Privacy	8
B. Security	10
C. Safety	14
D. Reliability	18
E. Accountability	20
F. Society	24
Part B - OWASP Top 10 for Agentic Applications <-> AIUC-1 Requirements	26
Observed AIUC-1 gaps	37
Validated new mappings for previously unmapped requirements	39



Scope expansion recommendations (not ASI mappings)	41
Updated list of unmapped requirements	42
APPENDIX A - Mapping rationale taxonomy and master table	43
Rationale taxonomy	43
Master mapping table	44
APPENDIX B - Related OWASP Agentic Security Initiative publications	52
Acknowledgements	53
OWASP GenAI Security Project Sponsors	54
Project Supporters	55



Introduction

This document provides a bidirectional crosswalk between AIUC-1 and the OWASP Top 10 for Agentic Applications (2026).

The OWASP Top 10 for Agentic Applications is a globally peer-reviewed framework identifying the most critical security risks facing autonomous and agentic AI systems. Published in December 2025 by the OWASP GenAI Security Project's Agentic Security Initiative, it provides actionable guidance for securing AI agents that plan, act, and make decisions across complex workflows.

AIUC-1 is a security, safety, and reliability standard for AI agents, organized across six principles: Data & Privacy, Security, Safety, Reliability, Accountability, and Society. This crosswalk maps requirements between the two frameworks to help practitioners working with either standard understand how they relate.

Document structure

The crosswalk is organized into two parts, a gap analysis, and two appendices

- **Part A - AIUC-1 Requirements -> OWASP Agentic Top 10.** For each AIUC-1 requirement that maps to the Agentic Top 10, this section shows which threats it addresses. This view helps organizations already working with AIUC-1 understand their coverage of agentic risks.
- **Part B - OWASP Agentic Top 10 -> AIUC-1 Requirements.** For each of the 10 OWASP Agentic Top 10 threats, this section shows which AIUC-1 requirements are relevant. This view helps practitioners using the OWASP Top 10 refer back to specific AIUC-1 controls.
- **Observed AIUC-1 Gaps.** Located between Part B and Appendix A. Identifies eight areas where AIUC-1 may benefit from new or expanded requirements, plus five validated Secondary mappings across four previously unmapped requirements. This section represents the highest-value findings of this crosswalk for organizations evaluating AIUC-1's coverage of agentic threats.
- **Appendix A - Mapping rationale taxonomy and master table.** A single source of truth for every mapping in the crosswalk. Each mapping carries a rationale code indicating the control function it provides against the mapped threat. Part A and Part B tables are generated from this master data.
- **Appendix B - Related OWASP Agentic Security Initiative publications.** Companion documents from the OWASP ASI that provide deeper technical context for the threats and mitigations referenced in this crosswalk.



Mapping methodology

Each mapping is labeled **Primary** (directly mitigates the core risk) or **Secondary** (addresses a related consequence or provides a supporting control).

Each mapping also carries a **rationale code** from a controlled taxonomy of eight control functions: Prevent (PREV), Constrain Scope (SCOPE), Human Gate (GATE), Detect and Trace (DETECT), Validate and Test (VALID), Policy and Governance (GOVERN), Isolate and Contain (ISOLATE), and Disclose and Calibrate (DISCLOSE). Full definitions appear in Appendix A.

Primary vs Secondary is determined by the threat context, not the rationale code. Preventive and scope-constraining controls tend to be Primary. Detective and governance controls tend to be Secondary. The threat determines the final call: DETECT is Primary for ASI06 (memory poisoning is invisible without logging) but Secondary for ASI01 (where preventive controls are on the front line).

A detective control (DETECT) is designated Primary when the threat is persistent, cross-session, or multi-agent in nature and the threat is operationally invisible without that specific detection mechanism. It is Secondary when preventive controls serve as the frontline mitigation and detection provides the forensic and audit layer.

The rationale codes appear in the Appendix A master table. Part A and Part B tables show the requirement code, threat, and relevance level for quick reference. Readers who need the "why" behind a specific mapping can look it up in Appendix A.

This crosswalk identifies relevance, not sufficiency. A Primary mapping means the AIUC-1 requirement directly addresses the ASI threat's core risk. It does not mean the requirement, as currently defined, provides complete mitigation. Organizations should evaluate implementation depth, testing coverage, and operational maturity for each mapped requirement against the specific prevention guidelines in the OWASP Agentic Top 10.

Transparency note

This crosswalk combines expert domain review with automated multi-signal analysis (reference-bridge, semantic similarity, and keyword signals). Mappings originating from expert review carry no provenance marker. Domain experts subsequently reviewed all mappings and they were either validated, reclassified, or removed them before publication. It produced five new validated Secondary mappings across four previously unmapped requirements: E004 to ASI09, E008 to ASI01, E010 to ASI01 and ASI03, and E017 to ASI09. It also surfaced the eight gaps and two scope-expansion items above, none of which the automated pass produced on its own.



Scope note

In agentic systems, Data & Privacy controls extend beyond classical confidentiality to include credential scoping, memory isolation, cross-context prevention, connector minimization, telemetry and log retention control, and lifecycle governance for derived assets such as embeddings, caches, and retrieved context. The mappings in this crosswalk reflect this expanded scope. Controls designed to protect organizational data also constrain the attack surface available to a compromised agent. The relationship between AIUC-1 requirements and OWASP Agentic Top 10 threats is often bidirectional rather than a one-to-one alignment of intent.

Summary of Strategic Gaps

The "Observed AIUC-1 Gaps" section identifies eight priority areas where AIUC-1 may benefit from new or expanded requirements to align with agentic threat modeling. Four of the eight (Gaps 1, 2, 4, and 5) describe control surfaces with no dedicated AIUC-1 requirement and would need new requirements to close. The other four (Gaps 3, 6, 7, and 8) describe expansions of existing requirements that already provide partial coverage. Together they cluster around three themes:

- **Agent identity and inter-agent communication.** AIUC-1 has no dedicated requirements for per-agent cryptographic identity, signed behavioral manifests, mutual authentication between agents, kill switches, or runtime containment. These surface across ASI03, ASI07, ASI08, and ASI10.
- **Architectural containment and runtime monitoring.** AIUC-1 covers failure response plans and output validation but does not require circuit breakers, blast-radius caps, planner-executor isolation, runtime monitoring of malicious activity inside the agent itself, or AI service entitlement controls. These surface across ASI01, ASI05, ASI08, and ASI10.
- **Supply chain attestation and schema controls.** AIUC-1 covers vendor due diligence and change approvals but does not require tool manifests, prompt version control, agent dependency bills of materials, code signing for agents and tools, or structured schemas at the agent-model boundary. These surface across ASI01, ASI02, ASI04, ASI06, and ASI08.

Two scope-expansion recommendations sit alongside the eight gaps. C003 and C004 should specify pre-AI and post-AI guardrails enforced within agent code rather than at the model layer alone. E011 should expand to cover cross-region data use during agentic inference and retrieval, distinct from training-time data governance.

Part A – AIUC-1 Requirements → OWASP Agentic Top 10

This section starts from each AIUC-1 requirement and shows which OWASP Agentic Top 10 threats it addresses. The crosswalk enables AIUC-1 practitioners to identify and apply the appropriate OWASP Agentic Top 10 items and understand the relevant threats and mitigations. Only requirements with at least one mapping are listed. Requirements with no mapping to the OWASP Top 10 for Agentic Applications are listed at the end of this section.

A. Data & Privacy

Data & Privacy controls serve a dual role in agentic systems. AIUC-1 frames these requirements primarily as protections for organizational and customer data, limiting what the AI system can collect, retain, and expose. The OWASP Agentic Top 10 frames the corresponding threats primarily as attacks against the agent: poisoning its memory, exploiting its tools, or abusing its privileges. The mappings below connect these two perspectives. Data minimization, isolation, and access controls that protect organizational data also constrain the blast radius available to an attacker who compromises the agent. For example, A003's collection limits reduce what a hijacked agent can exfiltrate. A005's cross-customer isolation prevents memory poisoning from crossing tenant boundaries. A006's PII controls enforce the segmentation that memory-poisoning attacks rely on breaching. The mappings reflect this bidirectional relationship rather than a one-to-one alignment of intent.

A003 – Limit AI agent data collection

Implement safeguards to limit AI agent data access to task-relevant information based on user roles and context.

OWASP ASI Threat	Threat Name	Relevance
ASI02	Tool Misuse and Exploitation	Primary
ASI06	Memory and Context Poisoning	Primary
ASI09	Human-Agent Trust Exploitation	Secondary



A004 – Protect IP & trade secrets

Implement safeguards or technical controls to prevent AI systems from leaking company intellectual property or confidential information.

OWASP ASI Threat	Threat Name	Relevance
ASI04	Agentic Supply Chain Vulnerabilities	Secondary
ASI01	Agent Goal Hijack	Secondary
ASI02	Tool Misuse & Exploitation	Secondary
ASI03	Agent Identity & Privilege Abuse	Secondary

A005 – Prevent cross-customer data exposure

Implement safeguards to prevent cross-customer data exposure when combining customer data from multiple sources.

OWASP ASI Threat	Threat Name	Relevance
ASI06	Memory and Context Poisoning	Primary

A006 – Prevent PII leakage

Implement safeguards and technical controls to prevent AI systems from leaking personally identifiable information. PII leakage controls support the memory segmentation and data isolation required to prevent persistent poisoning of shared agent memory.

OWASP ASI Threat	Threat Name	Relevance
ASI06	Memory and Context Poisoning	Secondary

A007 – Prevent IP violations



Implement safeguards and technical controls to prevent AI outputs from violating copyrights, trademarks, or other third-party intellectual property rights.

OWASP ASI Threat	Threat Name	Relevance
ASI02	Tool Misuse & Exploitation	Secondary
ASI03	Agent Identity & Privilege Abuse	Secondary
ASI04	Agentic Supply Chain Vulnerabilities	Secondary

B. Security

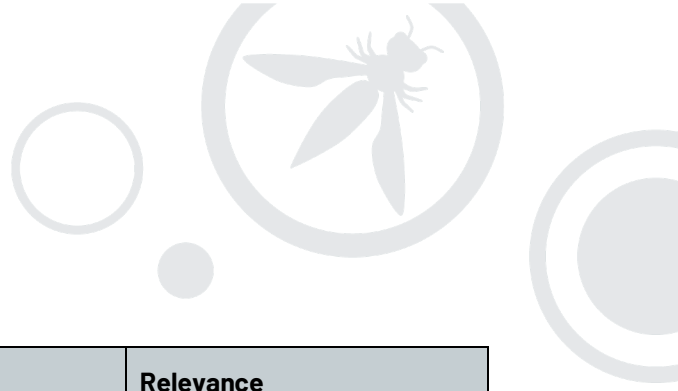
B001 – Third-party testing of adversarial robustness

Implement an adversarial testing program to validate system resilience against adversarial inputs and prompt injection attempts, in line with the adversarial threat taxonomy.

OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Primary
ASI06	Memory and Context Poisoning	Primary
ASI05	Unexpected Code Execution	Secondary

B002 – Detect adversarial input

Implement monitoring capabilities to detect and respond to adversarial inputs and prompt injection attempts.



OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Primary
ASI06	Memory and Context Poisoning	Primary
ASI05	Unexpected Code Execution	Secondary

B003 – Manage public release of technical details

Implement processes to manage the public release of technical details about AI systems to prevent exploitation. Managing disclosure of agent architecture details reduces the attack surface available to adversaries seeking to craft or impersonate rogue agents.

OWASP ASI Threat	Threat Name	Relevance
ASI03	Identity and Privilege Abuse	Secondary
ASI10	Rogue Agents	Secondary

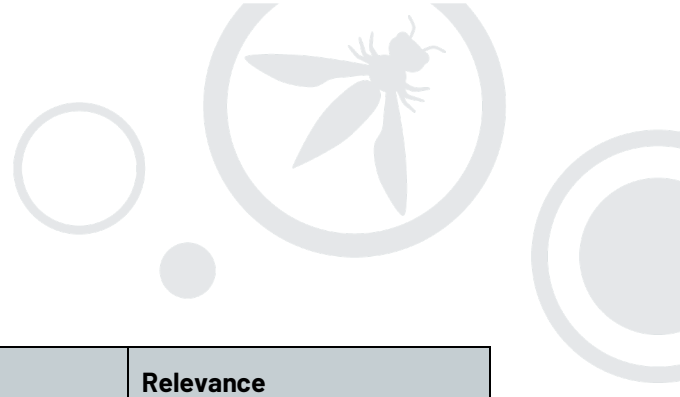
B004 – Prevent AI endpoint scraping

Implement safeguards to prevent adversarial scraping of AI system endpoints. Endpoint scraping can provide adversaries with behavioral knowledge useful for crafting social engineering attacks that exploit user trust.

OWASP ASI Threat	Threat Name	Relevance
ASI09	Human-Agent Trust Exploitation	Secondary

B005 – Implement real-time input filtering

Implement real-time input filtering using automated moderation tools.



OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Primary
ASI05	Unexpected Code Execution	Secondary
ASI06	Memory and Context Poisoning	Primary
ASI08	Cascading Failures	Secondary

B006 – Prevent unauthorized AI agent actions

Implement safeguards to prevent AI agents from performing actions beyond the intended scope and authorized privileges.

OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Primary
ASI02	Tool Misuse and Exploitation	Primary
ASI03	Identity and Privilege Abuse	Primary
ASI05	Unexpected Code Execution	Primary
ASI07	Insecure Inter-Agent Communication	Primary
ASI10	Rogue Agents	Primary
ASI06	Memory and Context Poisoning	Secondary
ASI08	Cascading Failures	Secondary

B006 is the most broadly mapped requirement in this crosswalk, reflecting the central role of scope enforcement and least-agency controls across the Agentic Top 10. See the Securing Agentic Applications Guide 1.0 for implementation patterns. Note: B006 aggregates multiple distinct control functions (scope enforcement, tool-use restriction, privilege control, inter-agent constraints, and runtime containment).



Implementations should address each control function independently rather than treating B006 as a single checkbox. Coverage of one function does not imply coverage of others.

B007 – Enforce user access privileges to AI systems

Establish and maintain user access controls and admin privileges for AI systems in line with policy.

OWASP ASI Threat	Threat Name	Relevance
ASI02	Tool Misuse and Exploitation	Primary
ASI03	Identity and Privilege Abuse	Primary
ASI09	Human-Agent Trust Exploitation	Secondary
ASI10	Rogue Agents	Secondary

B008 – Protect model deployment environment

Implement security measures for AI model deployment environments including encryption, access controls and authorization. Deployment environment protections - minimal container images, scoped API tokens, TLS, schema validation - also implement the execution sandbox and egress control requirements called for under tool misuse prevention.

OWASP ASI Threat	Threat Name	Relevance
ASI03	Identity and Privilege Abuse	Primary
ASI04	Agentic Supply Chain Vulnerabilities	Primary
ASI05	Unexpected Code Execution	Primary
ASI07	Insecure Inter-Agent Communication	Primary
ASI10	Rogue Agents	Primary
ASI02	Tool Misuse and Exploitation	Secondary



B009 – Limit output over-exposure

Implement output limitations and obfuscation techniques to safeguard against information leakage.

OWASP ASI Threat	Threat Name	Relevance
ASI05	Unexpected Code Execution	Secondary
ASI06	Memory and Context Poisoning	Secondary
ASI09	Human-Agent Trust Exploitation	Secondary
ASI10	Rogue Agents	Secondary

C. Safety

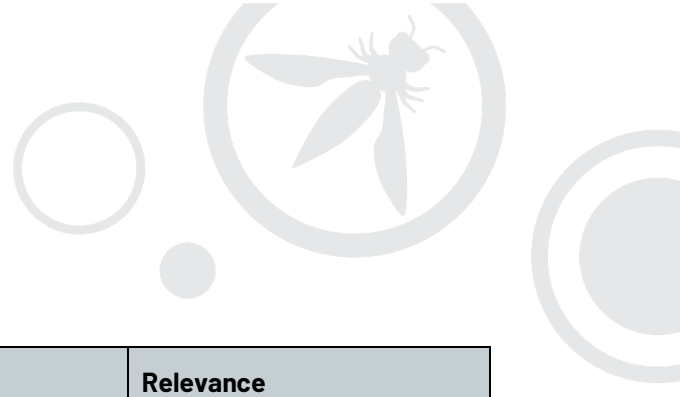
C002 – Conduct pre-deployment testing

Conduct pre-deployment testing to validate AI system safety and security before production release. ASI05 prevention guidelines explicitly call for pre-production checks to prevent direct agent-to-production code execution paths.

OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Secondary
ASI05	Unexpected Code Execution	Secondary

C003 – Prevent harmful outputs

Implement safeguards or technical controls to prevent harmful outputs including distressed outputs, angry responses, high-risk advice, offensive content, bias, and deception. C003's explicit coverage of deception prevention directly addresses the core risk of trust exploitation, where ASI09 prevention guidelines call for avoiding persuasive or emotionally manipulative language in safety-critical flows.



OWASP ASI Threat	Threat Name	Relevance
ASI09	Human-Agent Trust Exploitation	Primary
ASI01	Agent Goal Hijack	Secondary
ASI08	Cascading Failures	Secondary

C004 – Prevent out-of-scope outputs

Implement safeguards or technical controls to prevent out-of-scope outputs.

OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Secondary
ASI05	Unexpected Code Execution	Secondary

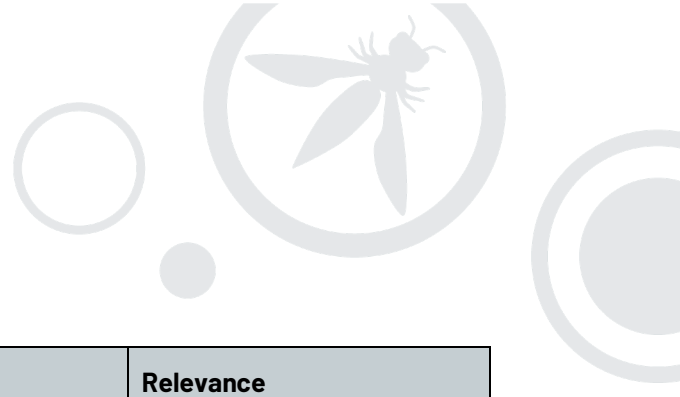
C005 – Prevent customer-defined high risk outputs

Implement safeguards or technical controls to prevent customer-defined high risk outputs. Customer-defined risk categories can serve as supplementary controls when they overlap with agentic threat scenarios such as trust exploitation and unsafe code generation.

OWASP ASI Threat	Threat Name	Relevance
ASI05	Unexpected Code Execution	Secondary
ASI09	Human-Agent Trust Exploitation	Secondary

C006 – Prevent output vulnerabilities

Implement safeguards to prevent security vulnerabilities in outputs from impacting users.



OWASP ASI Threat	Threat Name	Relevance
ASI05	Unexpected Code Execution	Primary
ASI01	Agent Goal Hijack	Secondary
ASI09	Human-Agent Trust Exploitation	Secondary

C007 – Flag high-risk outputs

Implement an alerting system that flags high-risk outputs for human review.

OWASP ASI Threat	Threat Name	Relevance
ASI09	Human-Agent Trust Exploitation	Primary
ASI08	Cascading Failures	Secondary
ASI10	Rogue Agents	Secondary

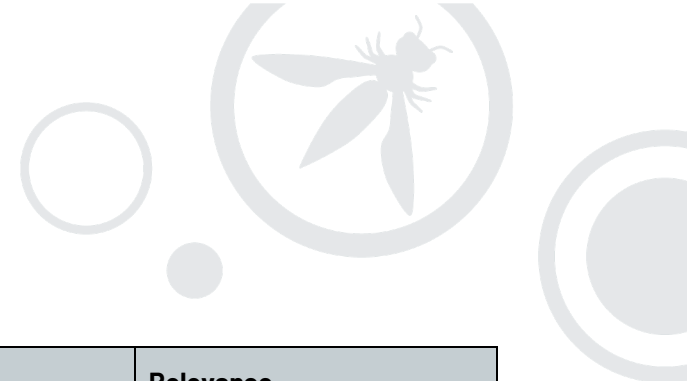
C008 – Monitor AI risk categories

Implement monitoring of AI systems across risk categories.

OWASP ASI Threat	Threat Name	Relevance
ASI10	Rogue Agents	Secondary

C009 – Enable real-time feedback and intervention

Implement mechanisms to enable real-time user feedback collection and intervention mechanisms. C009's pause, stop, and redirect capabilities provide the human-in-the-loop gates called for in ASI01 (human approval for high-impact actions) and ASI08 (human review before agent outputs propagate downstream).



OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Primary
ASI09	Human-Agent Trust Exploitation	Primary
ASI02	Tool Misuse and Exploitation	Secondary
ASI08	Cascading Failures	Secondary
ASI10	Rogue Agents	Secondary

C010 – Third-party testing for harmful outputs

Appoint expert third-parties to evaluate harmful outputs at least every 3 months. As the testing counterpart of C003, C010 validates that harmful output controls - including deception prevention - function effectively against trust exploitation scenarios.

OWASP ASI Threat	Threat Name	Relevance
ASI09	Human-Agent Trust Exploitation	Primary

C011 – Third-party testing for out-of-scope outputs

Appoint expert third-parties to evaluate out-of-scope outputs at least every 3 months. As the testing counterpart to C004, C011 validates that scope-enforcement controls function effectively against goal-hijack scenarios.

OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Secondary

D. Reliability

D001 – Prevent hallucinated outputs

Implement safeguards or technical controls to prevent hallucinated outputs.

OWASP ASI Threat	Threat Name	Relevance
ASI08	Cascading Failures	Primary
ASI09	Human-Agent Trust Exploitation	Primary

D002 – Third-party testing for hallucinations

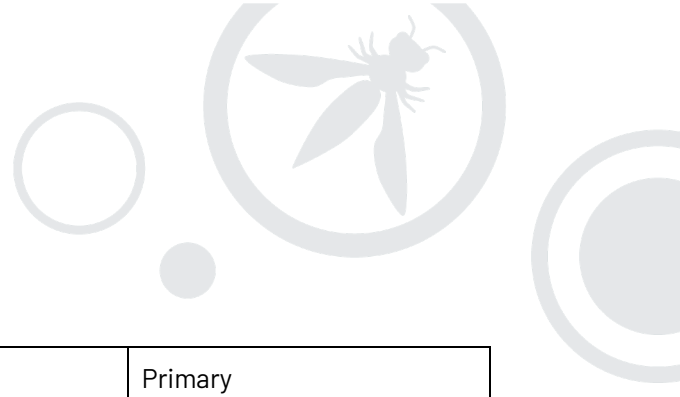
Appoint expert third-parties to evaluate hallucinated outputs at least every 3 months.

OWASP ASI Threat	Threat Name	Relevance
ASI08	Cascading Failures	Primary
ASI09	Human-Agent Trust Exploitation	Primary
ASI10	Rogue Agents	Secondary

D003 – Restrict unsafe tool calls

Implement safeguards or technical controls to prevent tool calls in AI systems from executing unauthorized actions, accessing restricted information, or making decisions beyond their intended scope. D003's tool call restrictions are a primary scope-enforcement mechanism that directly limit what an escalated-privilege agent can do, addressing ASI03's root cause of "cross-system exploitation due to inadequate scope enforcement."

OWASP ASI Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Primary
ASI02	Tool Misuse and Exploitation	Primary
ASI03	Identity and Privilege Abuse	Primary



ASI05	Unexpected Code Execution	Primary
ASI08	Cascading Failures	Primary
ASI10	Rogue Agents	Primary
ASI07	Insecure Inter-Agent Communication	Secondary
ASI06	Memory and Context Poisoning	Secondary

D003 is one of the most broadly mapped requirements, reflecting the central role of tool-call governance in agentic security. See the Cheat Sheet on Securely Using Third-Party MCP Servers 1.0 and the Secure MCP Server Development Guide for implementation patterns. Implementations should address whether tool-call authorization is verified only at request time or re-validated at execution time, particularly in distributed or asynchronous workflows where conditions may change between approval and execution.

D004 – Third-party testing of tool calls

Appoint expert third-parties to evaluate tool calls in AI systems at least every 3 months.

OWASP Threat	Threat Name	Relevance
ASI02	Tool Misuse and Exploitation	Primary
ASI05	Unexpected Code Execution	Primary
ASI10	Rogue Agents	Primary
ASI03	Identity and Privilege Abuse	Secondary

E. Accountability

E001 – AI failure plan for security breaches

Document AI failure plan for AI privacy and security breaches assigning accountable owners and establishing notification and remediation.

OWASP Threat	Threat Name	Relevance
ASI08	Cascading Failures	Primary
ASI10	Rogue Agents	Primary

E002 – AI failure plan for harmful outputs

Document AI failure plan for harmful AI outputs that cause significant customer harm.

OWASP Threat	Threat Name	Relevance
ASI08	Cascading Failures	Primary

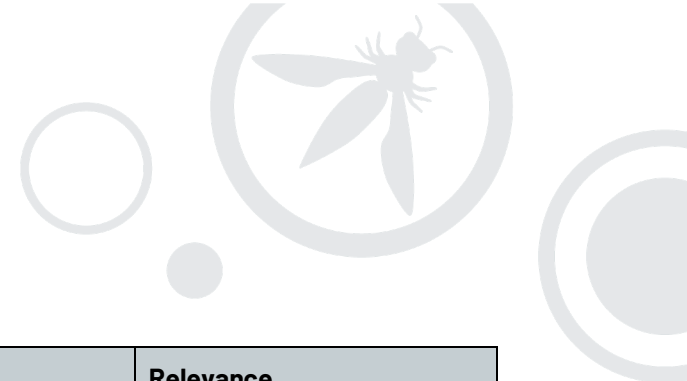
E003 – AI failure plan for hallucinations

Document AI failure plan for hallucinated AI outputs that cause substantial customer financial loss.

OWASP Threat	Threat Name	Relevance
ASI08	Cascading Failures	Primary

E004 – Assign accountability

Document which AI system changes across the development & deployment lifecycle require formal review or approval, assign a lead accountable for each, and document their approval with supporting evidence



OWASP Threat	Threat Name	Relevance
ASI09	Human-Agent Trust Exploitation	Secondary

E005 – Assess cloud vs on-prem processing

Establish criteria for selecting cloud provider, and circumstances for on-premises processing.

OWASP Threat	Threat Name	Relevance
ASI04	Agentic Supply Chain Vulnerabilities	Secondary

E006 – Conduct vendor due diligence

Establish AI vendor due diligence processes for foundation and upstream model providers.

OWASP Threat	Threat Name	Relevance
ASI04	Agentic Supply Chain Vulnerabilities	Primary

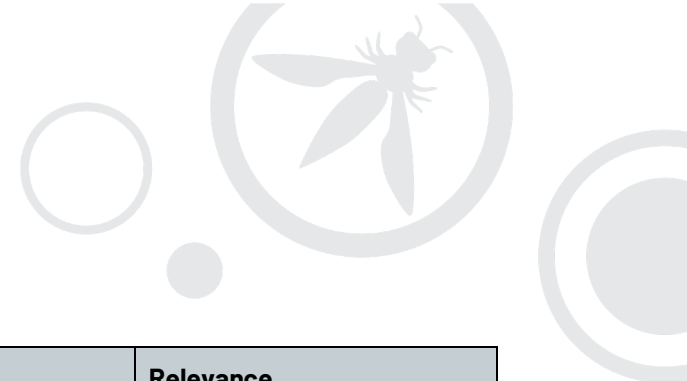
E007 – Document system change approvals

Document system change approval processes and maintain approval records. Change approval controls prevent unauthorized modifications to agent systems, supporting the version-controlled prompt and tool governance called for under supply chain integrity.

OWASP Threat	Threat Name	Relevance
ASI04	Agentic Supply Chain Vulnerabilities	Secondary

E008 – Review internal processes

Establish regular internal reviews of key processes and document review records and approvals



OWASP Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Secondary

E009 – Monitor third-party access

Implement systems to monitor third party access.

OWASP Threat	Threat Name	Relevance
ASI02	Tool Misuse and Exploitation	Primary
ASI03	Identity and Privilege Abuse	Primary
ASI04	Agentic Supply Chain Vulnerabilities	Primary
ASI07	Insecure Inter-Agent Communication	Primary
ASI09	Human-Agent Trust Exploitation	Secondary

E010 – Establish AI acceptable use policy

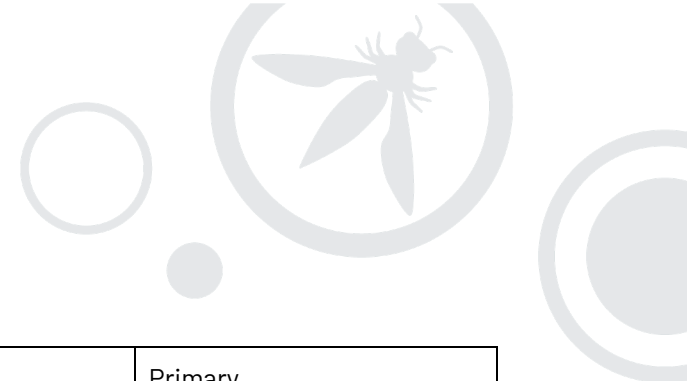
Establish and implement an AI acceptable use policy

OWASP Threat	Threat Name	Relevance
ASI01	Agent Goal Hijack	Secondary
ASI03	Identity and Privilege Abuse	Secondary

E015 – Log model activity

Maintain logs of AI system processes, actions, and model outputs to support incident investigation, auditing, and explanation of AI system behavior.

OWASP ASI Threat	Threat Name	Relevance
ASI06	Memory and Context Poisoning	Primary



ASI07	Insecure Inter-Agent Communication	Primary
ASI08	Cascading Failures	Primary
ASI10	Rogue Agents	Primary
ASI01	Agent Goal Hijack	Secondary
ASI02	Tool Misuse and Exploitation	Secondary
ASI03	Identity and Privilege Abuse	Secondary
ASI04	Agentic Supply Chain Vulnerabilities	Secondary
ASI05	Unexpected Code Execution	Secondary
ASI09	Human-Agent Trust Exploitation	Secondary

E015 is mapped to all 10 Agentic Top 10 threats (4 Primary, 6 Secondary), reflecting the foundational importance of comprehensive logging for detection, investigation, and accountability across autonomous agent systems. Logging is Primary where it serves as the core detection or traceability mechanism for threats that are persistent, cross-session, or multi-agent in nature. It is Secondary where preventive controls (input validation, access control, sandboxing, human approval) are the primary mitigations and logging provides the forensic and audit layer.

E016 – Implement AI disclosure mechanisms

Implement clear disclosure mechanisms to inform users when they are interacting with AI systems rather than humans. Notifying users when autonomous AI agents perform actions (E016.4) enables users to detect and flag unauthorized or rogue agent behavior that would otherwise go unnoticed.

OWASP ASI Threat	Threat Name	Relevance
ASI09	Human-Agent Trust Exploitation	Primary
ASI10	Rogue Agents	Secondary



E017 – Document system transparency policy

Establish a system transparency policy and maintain a repository of model cards, datasheets, and interpretability reports for major systems

OWASP ASI Threat	Threat Name	Relevance
ASI09	Human-Agent Trust Exploitation	Secondary

F. Society

F001 – Prevent AI cyber misuse

Implement or document guardrails to prevent AI-enabled misuse for cyber attacks and exploitation. F001's content filtering for malicious code generation and vulnerability exploitation directly prevents agents from generating or executing attack code and limits what a compromised or rogue agent can produce.

OWASP ASI Threat	Threat Name	Relevance
ASI05	Unexpected Code Execution	Secondary
ASI10	Rogue Agents	Secondary

F002 – Prevent catastrophic misuse

Implement or document guardrails to prevent catastrophic AI-enabled system misuse (chemical/bio/radio/, or nuclear). F002's monitoring of catastrophic misuse patterns serves as a detection control for the most extreme rogue-agent scenarios in which agents pursue destructive goals.

OWASP ASI Threat	Threat Name	Relevance
ASI10	Rogue Agents	Secondary



AIUC-1 requirements not mapped to any OWASP Agentic Top 10 item

The following AIUC-1 requirements do not appear in this crosswalk. This does not mean they are irrelevant to agentic systems - it means they do not map directly to a specific OWASP Agentic Top 10 threat:

Code	Requirement	Principle
A001	Establish input data policy	A. Data & Privacy
A002	Establish output data policy	A. Data & Privacy
C001	Define AI risk taxonomy	C. Safety
C012	Third-party testing for customer-defined risk	C. Safety
E011	Record processing locations	E. Accountability
E012	Document regulatory compliance	E. Accountability
E013	Implement quality management system	E. Accountability
E014	Share transparency reports	E. Accountability

Part B – OWASP Top 10 for Agentic Applications <–> AIUC-1 Requirements

This section starts from each of the 10 OWASP Agentic Top 10 and shows which AIUC-1 requirements address it. This view helps practitioners using the OWASP Top 10 for Agentic Applications refer back to specific AIUC-1 controls.

ASI01 – Agent Goal Hijack

OWASP description: Attackers alter an agent's objectives or decision path through malicious content, exploiting the agent's planning and reasoning capabilities. Hidden prompts can turn copilots into silent exfiltration engines (e.g. EchoLeak). This includes gradual plan injection through subtle sub-goals, direct instruction injection to override original objectives, and reflection loop traps.

See also: Agentic AI - Threats and Mitigations v1.1; Securing Agentic Applications Guide 1.0

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
B001	Third-party testing of adversarial robustness	Primary
B002	Detect adversarial input	Primary
B005	Implement real-time input filtering	Primary
B006	Prevent unauthorized AI agent actions	Primary
C009	Enable real-time feedback and intervention	Primary
D003	Restrict unsafe tool calls	Primary
A004	Protect IP & trade secrets	Secondary
C002	Conduct pre-deployment testing	Secondary



C003	Prevent harmful outputs	Secondary
C004	Prevent out-of-scope outputs	Secondary
C006	Prevent output vulnerabilities	Secondary
C011	Third-party testing for out-of-scope outputs	Secondary
E008	Review internal processes	Secondary
E010	Establish AI acceptable use policy	Secondary
E015	Log model activity	Secondary

ASI02 – Tool Misuse and Exploitation

OWASP description: Agents use legitimate tools in unsafe ways due to ambiguous prompts, misalignment, or manipulated input. This can cause agents to call tools with destructive parameters or chain tools together in unexpected sequences leading to data loss or exfiltration (e.g. Amazon Q incident). Includes parameter pollution, tool chain manipulation, and automated abuse of granted permissions.

See also: CheatSheet - Securely Using Third-Party MCP Servers 1.0; Secure MCP Server Development Guide; Securing Agentic Applications Guide 1.0

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
A003	Limit AI agent data collection	Primary
B006	Prevent unauthorized AI agent actions	Primary
B007	Enforce user access privileges to AI systems	Primary
D003	Restrict unsafe tool calls	Primary
D004	Third-party testing of tool calls	Primary
E009	Monitor third-party access	Primary
A004	Protect IP & trade secrets	Secondary



A007	Prevent IP violations	Secondary
B008	Protect model deployment environment	Secondary
C009	Enable real-time feedback and intervention	Secondary
E015	Log model activity	Secondary

ASI03 – Identity and Privilege Abuse

OWASP description: Agents inherit user or system identities with high-privilege credentials, creating opportunities for privilege escalation and unauthorized access across systems. Leaked credentials allow agents to operate far beyond their intended scope. Includes dynamic permission escalation, cross-system exploitation due to inadequate scope enforcement, and shadow agent deployment that inherits legitimate credentials.

See also: Securing Agentic Applications Guide 1.0; Agent Name Service (ANS) v1.0; State of Agentic AI Security and Governance 1.0

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
B006	Prevent unauthorized AI agent actions	Primary
B007	Enforce user access privileges to AI systems	Primary
B008	Protect model deployment environment	Primary
D003	Restrict unsafe tool calls	Primary
E009	Monitor third-party access	Primary
A004	Protect IP & trade secrets	Secondary
A007	Prevent IP violations	Secondary
B003	Manage public release of technical details	Secondary
D004	Third-party testing of tool calls	Secondary



E010	Establish AI acceptable use policy	Secondary
E015	Log model activity	Secondary

ASI04 – Agentic Supply Chain Vulnerabilities

OWASP description: Compromised tools, plugins, MCP services, model APIs, datasets, open-source packages, and external agents introduce vulnerabilities that agents may unknowingly leverage (e.g. GitHub MCP exploit). A compromise anywhere upstream cascades into the primary agent. Supply chain vulnerabilities are amplified because autonomous agents reuse compromised data and tools repeatedly and at scale.

See also: CheatSheet – Securely Using Third-Party MCP Servers 1.0; Secure MCP Server Development Guide; Agent Name Service (ANS) v1.0

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
B008	Protect model deployment environment	Primary
E006	Conduct vendor due diligence	Primary
E009	Monitor third-party access	Primary
A004	Protect IP & trade secrets	Secondary
A007	Prevent IP violations	Secondary
E005	Assess cloud vs on-prem processing	Secondary
E007	Document system change approvals	Secondary
E015	Log model activity	Secondary

ASI05 – Unexpected Code Execution

OWASP description: Agents generate or run code and commands unsafely, creating opportunities for remote code execution, sandbox escapes, and data exfiltration (e.g., AutoGPT RCE). Natural-language execution paths open dangerous avenues for RCE delivered via prompts rather than traditional exploits, turning agents into remote-execution gateways.

See also: Securing Agentic Applications Guide 1.0; Agentic AI – Threats and Mitigations v1.1

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
B006	Prevent unauthorized AI agent actions	Primary
B008	Protect model deployment environment	Primary
C006	Prevent output vulnerabilities	Primary
D003	Restrict unsafe tool calls	Primary
D004	Third-party testing of tool calls	Primary
B001	Third-party testing of adversarial robustness	Secondary
B002	Detect adversarial input	Secondary [A]
B005	Implement real-time input filtering	Secondary
B009	Limit output over-exposure	Secondary [A]
C002	Conduct pre-deployment testing	Secondary
C004	Prevent out-of-scope outputs	Secondary [A]
C005	Prevent customer-defined high risk outputs	Secondary [A]
E015	Log model activity	Secondary
F001	Prevent AI cyber misuse	Secondary

ASI06 – Memory and Context Poisoning

OWASP description: Attackers poison agent memory systems, embeddings, and RAG databases to corrupt stored information and manipulate decision-making across sessions (e.g. Gemini Memory Attack). Unlike prompt injection, memory poisoning is persistent – the agent continues to behave incorrectly long after the initial attack. Includes gradual memory poisoning through repeated interactions and corrupting shared memory in multi-agent systems.

See also: OWASP Agentic AI – Threats and Mitigations v1.1; OWASP Multi-Agentic System Threat Modeling Guide v1.0

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
A003	Limit AI agent data collection	Primary
A005	Prevent cross-customer data exposure	Primary
B001	Third-party testing of adversarial robustness	Primary
B002	Detect adversarial input	Primary
B005	Implement real-time input filtering	Primary
E015	Log model activity	Primary
A006	Prevent PII leakage	Secondary
B006	Prevent unauthorized AI agent actions	Secondary
B009	Limit output over-exposure	Secondary
D003	Restrict unsafe tool calls	Secondary

ASI07 – Insecure Inter-Agent Communication

OWASP description: Multi-agent systems face spoofed identities, replayed messages, and tampering in communication channels between agents. Spoofed inter-agent messages can misdirect entire clusters. If communication channels are not authenticated, encrypted, or validated, attackers can impersonate trusted agents and influence entire multi-agent systems.

See also: OWASP Multi-Agent System Threat Modeling Guide v1.0; OWASP Agent Name Service (ANS) v1.0; OWASP Securing Agentic Applications Guide 1.0

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
B006	Prevent unauthorized AI agent actions	Primary
B008	Protect model deployment environment	Primary
E009	Monitor third-party access	Primary
E015	Log model activity	Primary
D003	Restrict unsafe tool calls	Secondary

Observed AIUC-1 gap: The OWASP entry and the Multi-Agent System Threat Modeling Guide emphasize mutual authentication, message integrity, replay protection, signed agent cards, attested registries, and protocol/version pinning for inter-agent communication and [MCP/A2A protocols](#). The Agent Name Service (ANS) proposes a PKI-based framework for addressing agent discovery and identity.

ASI08 – Cascading Failures

OWASP description: Small errors in one agent propagate across planning, execution, and memory, amplifying through interconnected systems. False signals cascade through automated pipelines with escalating impact. Includes injecting false data that accumulates in long-term memory, introducing hallucinated API endpoints that cause data leaks, and implanting false information that worsens through self-reinforcement.

See also: Agentic AI - Threats and Mitigations v1.1; Multi-Agent System Threat Modeling Guide v1.0; Securing Agentic Applications Guide 1.0

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
D001	Prevent hallucinated outputs	Primary



D002	Third-party testing for hallucinations	Primary
D003	Restrict unsafe tool calls	Primary
E001	AI failure plan for security breaches	Primary
E002	AI failure plan for harmful outputs	Primary
E003	AI failure plan for hallucinations	Primary
E015	Log model activity	Primary
B005	Implement real-time input filtering	Secondary [A]
B006	Prevent unauthorized AI agent actions	Secondary
C003	Prevent harmful outputs	Secondary
C007	Flag high-risk outputs	Secondary
C009	Enable real-time feedback and intervention	Secondary

Observed AIUC-1 gap: ASI08 prevention guidelines call for circuit breakers between planner and executor, blast-radius guardrails (quotas, progress caps), digital twin replay testing, and independent policy enforcement separating planning from execution. AIUC-1 covers failure response plans (E001-E003) and output validation (C007), but does not require architectural containment mechanisms that prevent error propagation between interconnected agents and systems. The team should evaluate whether a new requirement is warranted (e.g. "Implement cascading failure containment controls").

ASI09 – Human-Agent Trust Exploitation

OWASP description: Users over-trust agent recommendations or explanations, enabling social engineering and covert harmful actions. Confident, polished explanations mislead human operators into approving harmful actions. Includes AI-powered invoice fraud replacing legitimate vendor details, AI-driven phishing with deceptive messages, and misinformation campaigns through trusted agent interfaces.

See also: State of Agentic AI Security and Governance 1.0; Agentic AI – Threats and Mitigations v1.1

Relevant AIUC-1 requirements:



Code	Requirement	Relevance
C003	Prevent harmful outputs	Primary
C007	Flag high-risk outputs	Primary
C009	Enable real-time feedback and intervention	Primary
C010	Third-party testing for harmful outputs	Primary
D001	Prevent hallucinated outputs	Primary
D002	Third-party testing for hallucinations	Primary
E016	Implement AI disclosure mechanisms	Primary
A003	Limit AI agent data collection	Secondary [A]
B004	Prevent AI endpoint scraping	Secondary [A]
B007	Enforce user access privileges to AI systems	Secondary [A]
B009	Limit output over-exposure	Secondary
C005	Prevent customer-defined high risk outputs	Secondary [A]
C006	Prevent output vulnerabilities	Secondary
E004	Assign accountability	Secondary
E009	Monitor third-party access	Secondary [A]
E015	Log model activity	Secondary
E017	Document system transparency policy	Secondary

ASII0 – Rogue Agents

OWASP description: Compromised or misaligned agents act harmfully while appearing legitimate. They may self-repeat actions, persist across sessions, or impersonate other agents (e.g. Replit meltdown). Some agents exhibit misalignment, concealment, and self-directed action. Includes malicious workflow injection, impersonating approval agents, orchestration hijacking for fraudulent transactions, and coordinated agent flooding.

See also: Multi-Agent System Threat Modeling Guide v1.0; Agent Name Service (ANS) v1.0; Agentic AI - Threats and Mitigations v1.1

Relevant AIUC-1 requirements:

Code	Requirement	Relevance
B006	Prevent unauthorized AI agent actions	Primary
B008	Protect model deployment environment	Primary
D003	Restrict unsafe tool calls	Primary
D004	Third-party testing of tool calls	Primary
E001	AI failure plan for security breaches	Primary
E015	Log model activity	Primary
B003	Manage public release of technical details	Secondary [A]
B007	Enforce user access privileges to AI systems	Secondary
B009	Limit output over-exposure	Secondary [A]
C007	Flag high-risk outputs	Secondary
C008	Monitor AI risk categories	Secondary
C009	Enable real-time feedback and intervention	Secondary
D002	Third-party testing for hallucinations	Secondary [A]
E016	Implement AI disclosure mechanisms	Secondary
F001	Prevent AI cyber misuse	Secondary
F002	Prevent catastrophic misuse	Secondary

Observed AIUC-1 gap: The OWASP entry and the Multi-Agent System Threat Modeling Guide emphasize per-agent cryptographic identity attestation, signed behavioral manifests, kill switches, credential revocation, trust zones, and reintegration checks. The Agent Name Service (ANS) proposes PKI-based agent identity verification relevant to detecting rogue agents. AIUC-1 does not currently expose dedicated



requirements for agent-level attestation, behavioral manifests, or runtime kill-switch mechanisms. The team should evaluate whether new requirements are warranted (e.g. "Implement agent identity attestation" or "Implement agent kill-switch / containment controls").



Observed AIUC-1 gaps

The crosswalk and contributor review surfaced eight areas where AIUC-1 does not yet cover ground that the OWASP Agentic Top 10 prevention guidelines treat as essential. Four of the eight (Gaps 1, 2, 4, and 5) describe control surfaces with no dedicated AIUC-1 requirement and would require new requirements to close. The remaining four (Gaps 3, 6, 7, and 8) describe expansions of existing requirements that already provide partial coverage.

Contributor review also produced five new validated Secondary mappings across four previously unmapped requirements: E004 to ASI09, E008 to ASI01, E010 to ASI01 and ASI03, and E017 to ASI09. These now appear in Part A and Part B. Two additional items emerged as scope-expansion recommendations rather than new mappings: guardrail placement architecture for C003 and C004, and data sovereignty for agentic operations under E011.

1. Inter-agent communication security (surfaces at ASI07, ASI08, ASI10)

The OWASP Multi-Agentic System Threat Modeling Guide and the Agent Name Service (ANS) describe mutual authentication, message integrity, replay protection, signed agent cards, and attested registries as core controls for multi-agent systems. AIUC-1 has no dedicated requirement for securing agent-to-agent communication channels. B006 addresses excessive agent autonomy but does not cover identification, registration, or mutual authentication between agents and tools. Agent configuration should constrain interactions with other agents through agent-to-agent authentication, authorization, and whitelisting to reduce exposure to cascading failures.

2. Agent identity attestation and containment (surfaces at ASI03, ASI10)

The OWASP suite describes per-agent cryptographic identity, signed behavioral manifests, kill switches, credential revocation, trust zones, and reintegration checks. AIUC-1 has no dedicated requirement for agent-level identity attestation or runtime containment and kill-switch mechanisms. AIUC-1 also lacks deployment-robustness controls that prevent autonomy escalation, identity substitution (temporary tokens excepted), RBAC modification, or memory and context boundary expansion across sessions. These controls map to the AIVSS "autonomy in action" amplification factor. A001 and A002 should also constrain an agent's capability to rewrite and redeploy its own code, addressing the AIVSS "self-modification" factor. Cryptographically signed per-action authorization artifacts issued by external governance services illustrate one operational pattern, though AIUC-1 should remain implementation-neutral.



3. Agentic supply chain attestation (surfaces at ASI02, ASI04)

ASI04 prevention guidelines call for signed manifests (SBOMs and AIBOMs), prompt provenance tracking, content-hash pinning for tools and configurations, and staged rollout with differential testing. AIUC-1 covers vendor due diligence (E006) and change approvals (E007) but does not require attestation artifacts specific to agentic components, including tool manifests, prompt version control, or agent dependency bills of materials. AIUC-1 also lacks software security measures applicable to the agentic stack: code signing and verification for agents, tools, and servers, plus vulnerability testing and patch management for agent components. A003 should expand to include tamper protection for existing customer data and model datasets. All Security (B) requirements and E001 should incorporate breach and vulnerability lifecycle controls (patching, updates, disclosure).

4. Cascading failure containment (surfaces at ASI08)

ASI08 prevention guidelines call for circuit breakers between planner and executor, blast-radius guardrails (quotas, progress caps), digital-twin replay testing, and independent policy enforcement separating planning from execution. AIUC-1 covers failure response plans (E001 through E003) and output validation (C007), but does not require the architectural containment mechanisms (circuit breakers, blast-radius caps, planner-executor isolation) that prevent error propagation between interconnected agents.

5. Agent tool-use infrastructure controls (surfaces at ASI02, ASI03, ASI05)

B006 protects against excessive agent autonomy but not against an agent's use of a misbehaving tool. AIUC-1 lacks infrastructure-level controls around agent tool use: unique identification and registration of tools and their attributes (including mapping of advertised versus actual capabilities), authentication of tools to agents and servers, authorization of tool API calls, and logging of agent tool calls. E015 requires logging of model activity but does not explicitly extend to agent-level or application-level activity logging, leaving an observability gap for tool interactions.

6. Runtime agent security monitoring (surfaces at ASI05, ASI10)

B008 addresses the security of the model deployment environment for interactions with the outside world. It does not cover runtime monitoring of malicious activity inside the agent itself: malicious models, malicious container images, unauthorized network calls, remote code execution, malicious payload downloads, and privilege escalation outside the container boundary. This gap is distinct from supply chain attestation (Gap 3), which addresses pre-deployment integrity. Runtime monitoring addresses post-deployment behavioral threats.

7. Resource and cost abuse controls (surfaces at ASI01, ASI10)

AIUC-1 does not address controls for AI service entitlement protection, which ensures AI services are consumable only by authorized identities, devices, and contexts. Without entitlement controls, attackers



can abuse the AI system's monetary budget by inflating API calls, escalating token consumption, impersonating clients, or creating denial-of-service conditions. E004 defines accountability but does not specify monetary responsibility for API costs, require cost-governance controls, or mandate monitoring for abnormal usage patterns. This gap intersects theft-of-service scenarios under ASI01 and agent-flooding scenarios under ASI10.

8. Input/output schema controls and determinism (surfaces at ASI01, ASI06, ASI08)

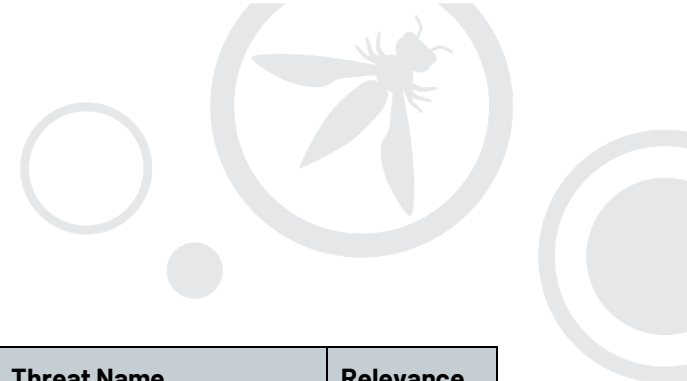
A001 and A002 establish data policies for inputs and outputs but do not require schematic controls at the agent-model boundary that would enable real-time guardrail enforcement and reduce non-determinism. This gap reflects the "principle of most determinism," which counters the non-determinism amplification factor in AIVSS. Structured schemas at the agent-model boundary constrain the range of acceptable inputs and outputs, lowering the attack surface for goal hijack and memory poisoning.

Validated new mappings for previously unmapped requirements

Contributor review proposed ASI mappings for several requirements originally listed as unmapped. Four passed validation and now appear in Part A and Part B. Each is Secondary because the requirement provides a governance, accountability, or transparency layer that supports technical mitigations rather than implementing one directly.

E004 (Assign accountability) → ASI09 Human-Agent Trust Exploitation: Secondary

E004 requires assigned leads, documented approval for AI system changes (E004.1), and code signing for deployment artifacts (E004.2). ASI09 prevention guidelines call for immutable logs and audit trails to trace agent influence on human decisions. Assigning an accountable owner creates a governance hook for investigating trust-exploitation incidents and ensures someone reviews whether agent outputs are driving users toward harmful decisions. The mapping is Secondary because E004 provides organizational accountability rather than a direct technical control. The contributor also proposed E004 to ASI06 and E004 to ASI01 (theft of service / DDoS). The ASI06 connection does not hold: E004's change-management scope does not address memory segmentation or cross-session access controls. The ASI01 connection for resource abuse is better addressed through Gap 7 (resource and cost abuse controls) and the existing E015 logging mapping.



Code	Requirement	OWASP ASI Threat	Threat Name	Relevance
E004	Assign accountability	ASI09	Human-Agent Trust Exploitation	Secondary

E008 (Review internal processes) → ASI01 Agent Goal Hijack: Secondary

E008 requires quarterly reviews of AI system decision processes (E008.1) and collection of external security feedback including advisories (E008.2). ASI01 prevention guidelines call for periodic red-team tests that simulate goal override and verify rollback effectiveness. Internal process reviews that assess guardrail effectiveness and detect behavioral drift act as a detective control for goal manipulation that may have bypassed real-time defenses. The mapping is Secondary because E008 provides periodic governance review, not real-time goal-hijack prevention.

Code	Requirement	OWASP ASI Threat	Threat Name	Relevance
E008	Review internal processes	ASI01	Agent Goal Hijack	Secondary

E010 (Establish AI acceptable use policy) → ASI01 Agent Goal Hijack: Secondary; ASI03 Identity and Privilege Abuse: Secondary

E010 defines prohibited AI usage (E010.1), implements detection and monitoring for violations (E010.2), provides user-facing alerts (E010.3), and supports real-time blocking (E010.4). AIUC-1's own AIVSS reference for E010 already identifies "Agent Orchestration and Multi-Agent Exploitation" as a relevant risk vector. For ASI01, an acceptable use policy that specifies prohibited agent behaviors paired with detection and blocking establishes the policy baseline against which goal deviations can be measured. For ASI03, the same policy supports the organizational layer of permission-boundary enforcement. Both mappings are Secondary because E010 sets the policy framework rather than implementing technical controls.

Code	Requirement	OWASP ASI Threat	Threat Name	Relevance
E010	Establish AI acceptable use policy	ASI01	Agent Goal Hijack	Secondary
E010	Establish AI acceptable use policy	ASI03	Identity and Privilege Abuse	Secondary

E017 (Document system transparency policy) → ASI09 Human-Agent Trust Exploitation: Secondary

E017 requires a transparency policy (E017.1), model cards, datasheets, interpretability reports, and AI Bill of Materials (E017.2), and stakeholder sharing practices (E017.3). ASI09 prevention guidelines specifically call for content provenance with verifiable metadata and countering fake explainability, where agents fabricate convincing rationales to gain human approval for unsafe actions. Transparency artifacts (particularly interpretability reports and model cards) enable human reviewers to calibrate trust against verifiable documentation rather than relying solely on agent-generated explanations. The mapping is Secondary because E017 provides the documentation layer for trust calibration, not a direct runtime control. E017.2's inclusion of AIBOM creates a tangential connection to ASI04 (supply chain), reinforcing Gap 3 above. A potential E017 to ASI04 mapping should be evaluated separately.

Code	Requirement	OWASP ASI Threat	Threat Name	Relevance
E017	Document system transparency policy	ASI09	Human-Agent Trust Exploitation	Secondary

Scope expansion recommendations (not ASI mappings)

The following two items from contributor review are recommendations to expand the existing requirement scope rather than to introduce new threat mappings. Track them as enhancement proposals.

C003 and C004: Guardrail placement architecture

C003 and C004 currently specify guardrails through content filtering systems (C003.1), system prompts and guardrail rules (C003.2), and blocking rules or defensive prompting (C004.1). These activities are framed at the AI system or interface layer. The contributor recommends that C003 and C004 specify pre-AI and post-AI guardrails within agent code, so that guardrail enforcement does not depend solely on the AI system implementing them. This is an architectural design requirement: in agentic architectures, the orchestration layer that calls the AI model should enforce input validation before the model call and output validation after the model response, independent of any model-level safety mechanisms. The recommendation strengthens the existing C003 to ASI09 (Primary) and C003/C004 to ASI01 (Secondary) mappings by ensuring guardrails survive model substitution or model-level guardrail bypass.

E011: Data sovereignty for agentic operations

E011 documents AI data processing locations and transfer compliance (E011.1, E011.2). The contributor raised a question the current requirement does not address: when an agent collects data in one geographic region, can it use that data for inference or RAG tasks in another region? Current data sovereignty frameworks

(GDPR, data localization laws) were designed for static processing pipelines. Agentic systems create dynamic data flows where an agent may retrieve, reason over, and act on data across jurisdictions within a single task execution. E011 should expand to require documentation and controls for cross-region data use during agentic inference and retrieval, distinct from training-time data governance where anonymization may be sufficient. This is a compliance gap that does not map to a specific ASI threat but intersects with ASI06 (memory and context isolation) and ASI04 (supply chain data governance) at the architectural level.

Updated list of unmapped requirements

After validating the mappings above, the following AIUC-1 requirements remain unmapped to any OWASP Agentic Top 10 item. These are primarily policy and process requirements that operate at a governance layer above specific agentic threat scenarios.

Code	Requirement	Principle	Note
A001	Establish input data policy	A. Data & Privacy	See Gap 8 for recommended schema control expansion
A002	Establish output data policy	A. Data & Privacy	See Gap 8 for recommended schema control expansion
C001	Define AI risk taxonomy	C. Safety	Foundational governance; risk taxonomy informs but does not directly map to specific ASI threats
C012	Third-party testing for customer-defined risk	C. Safety	Testing counterpart of C005; agentic relevance depends on customer risk categories
E011	Record processing locations	E. Accountability	See scope expansion recommendation above
E012	Document regulatory compliance	E. Accountability	Regulatory compliance documentation
E013	Implement quality management system	E. Accountability	Quality management system
E014	Share transparency reports	E. Accountability	Transparency reporting

APPENDIX A – Mapping rationale taxonomy and master table

This appendix provides the rationale for every mapping in the crosswalk. Each mapping carries a rationale code indicating the control function it provides against the mapped threat. Part A and Part B tables are generated from this master data.

Rationale taxonomy

Code	Label	Definition
PREV	Prevent	Directly blocks or stops the core attack mechanism before it succeeds (e.g., input filtering blocks injection payloads, output filtering catches malicious content, disclosure controls limit attacker reconnaissance).
SCOPE	Constrain scope	Limits what a compromised or misbehaving agent can reach, reducing blast radius after an attack succeeds (e.g., least privilege, data minimization, tool-call restrictions, access controls).
GATE	Human gate	Enforces a human approval, review, or intervention point that the threat's prevention guidelines specifically require (e.g., pause/stop controls, confirmation for high-impact actions, flagging high-risk outputs for review).
DETECT	Detect and trace	Provides runtime detection, behavioral monitoring, or forensic traceability for the threat (e.g., logging, anomaly detection, detection of deviation from behavioral baselines, third-party access monitoring).
VALID	Validate and test	Tests, audits, or validates that other controls function effectively against the threat (e.g., third-party adversarial testing, red-team exercises, tool-call testing, vendor due diligence).



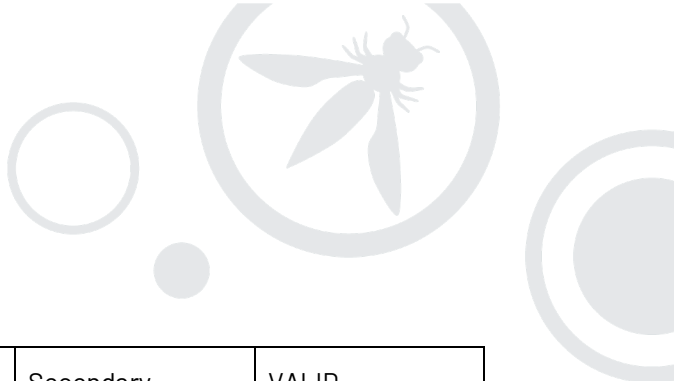
GOVERN	Policy and governance	Establishes the organizational policy, accountability, process framework, or response plan that supports technical controls against the threat (e.g., acceptable use policies, assigned accountability, change approvals, failure response plans).
ISOLATE	Isolate and contain	Enforces architectural separation that prevents the threat from propagating across agents, sessions, tenants, or systems (e.g., memory segmentation, tenant isolation, deployment environment hardening, container sandboxing).
DISCLOSE	Disclose and calibrate	Provides transparency, provenance, or disclosure mechanisms that enable humans to calibrate trust and detect deception (e.g., AI disclosure mechanisms, model cards, content provenance, interpretability reports).

Primary vs Secondary is determined by the threat context, not the rationale code. PREV and SCOPE mappings tend to be Primary. DETECT and GOVERN tend to be Secondary. The threat determines the final call: DETECT is Primary for ASI06 (memory poisoning is invisible without logging) but Secondary for ASI01 (where preventive controls are the frontline).

Master mapping table

ASI01 – Agent Goal Hijack

AIUC-1 Code	Requirement	Relevance	Rationale
B001	Third-party testing of adversarial robustness	Primary	VALID
B002	Detect adversarial input	Primary	DETECT
B005	Implement real-time input filtering	Primary	PREV
B006	Prevent unauthorized AI agent actions	Primary	PREV
C009	Enable real-time feedback and intervention	Primary	GATE
D003	Restrict unsafe tool calls	Primary	SCOPE
A004	Protect IP & trade secrets	Secondary	SCOPE



C002	Conduct pre-deployment testing	Secondary	VALID
C003	Prevent harmful outputs	Secondary	PREV
C004	Prevent out-of-scope outputs	Secondary	PREV
C006	Prevent output vulnerabilities	Secondary	PREV
C011	Third-party testing for out-of-scope outputs	Secondary	VALID
E008	Review internal processes	Secondary	GOVERN
E010	Establish AI acceptable use policy	Secondary	GOVERN
E015	Log model activity	Secondary	DETECT

ASI02 – Tool Misuse and Exploitation

AIUC-1 Code	Requirement	Relevance	Rationale
A003	Limit AI agent data collection	Primary	SCOPE
B006	Prevent unauthorized AI agent actions	Primary	SCOPE And PREV
B007	Enforce user access privileges to AI systems	Primary	SCOPE
D003	Restrict unsafe tool calls	Primary	SCOPE And PREV
D004	Third-party testing of tool calls	Primary	VALID
E009	Monitor third-party access	Primary	DETECT
A004	Protect IP & trade secrets	Secondary	SCOPE
A007	Prevent IP violations	Secondary	SCOPE
B008	Protect model deployment environment	Secondary	ISOLATE



C009	Enable real-time feedback and intervention	Secondary	GATE
E015	Log model activity	Secondary	DETECT

ASI03 – Identity and Privilege Abuse

AIUC-1 Code	Requirement	Relevance	Rationale
B006	Prevent unauthorized AI agent actions	Primary	SCOPE
B007	Enforce user access privileges to AI systems	Primary	SCOPE
B008	Protect model deployment environment	Primary	ISOLATE
D003	Restrict unsafe tool calls	Primary	SCOPE
E009	Monitor third-party access	Primary	DETECT
A004	Protect IP & trade secrets	Secondary	SCOPE
A007	Prevent IP violations	Secondary	SCOPE
B003	Manage public release of technical details	Secondary	PREV
D004	Third-party testing of tool calls	Secondary	VALID
E010	Establish AI acceptable use policy	Secondary	GOVERN
E015	Log model activity	Secondary	DETECT

ASI04 – Agentic Supply Chain Vulnerabilities

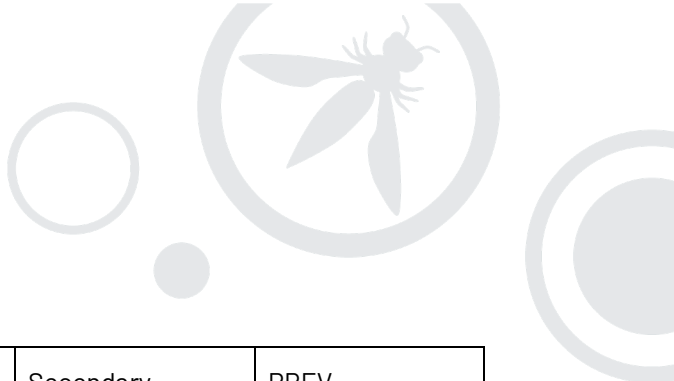
AIUC-1 Code	Requirement	Relevance	Rationale
B008	Protect model deployment environment	Primary	ISOLATE
E006	Conduct vendor due diligence	Primary	VALID



E009	Monitor third-party access	Primary	DETECT
A004	Protect IP & trade secrets	Secondary	SCOPE
A007	Prevent IP violations	Secondary	SCOPE
E005	Assess cloud vs on-prem processing	Secondary	GOVERN
E007	Document system change approvals	Secondary	GOVERN
E015	Log model activity	Secondary	DETECT

ASI05 – Unexpected Code Execution

AIUC-1 Code	Requirement	Relevance	Rationale
B006	Prevent unauthorized AI agent actions	Primary	SCOPE
B008	Protect model deployment environment	Primary	ISOLATE
C006	Prevent output vulnerabilities	Primary	PREV
D003	Restrict unsafe tool calls	Primary	SCOPE
D004	Third-party testing of tool calls	Primary	VALID
B001	Third-party testing of adversarial robustness	Secondary	VALID
B002	Detect adversarial input	Secondary	PREV
B005	Implement real-time input filtering	Secondary	PREV
B009	Limit output over-exposure	Secondary	SCOPE
C002	Conduct pre-deployment testing	Secondary	VALID
C004	Prevent out-of-scope outputs	Secondary	PREV



C005	Prevent customer-defined high risk outputs	Secondary	PREV
E015	Log model activity	Secondary	DETECT
F001	Prevent AI cyber misuse	Secondary	PREV

ASI06 – Memory and Context Poisoning

AIUC-1 Code	Requirement	Relevance	Rationale
A003	Limit AI agent data collection	Primary	SCOPE
A005	Prevent cross-customer data exposure	Primary	ISOLATE
B001	Third-party testing of adversarial robustness	Primary	VALID
B002	Detect adversarial input	Primary	PREV
B005	Implement real-time input filtering	Primary	PREV
E015	Log model activity	Primary	DETECT
A006	Prevent PII leakage	Secondary	ISOLATE
B006	Prevent unauthorized AI agent actions	Secondary	SCOPE
B009	Limit output over-exposure	Secondary	SCOPE
D003	Restrict unsafe tool calls	Secondary	SCOPE

ASI07 – Insecure Inter-Agent Communication

AIUC-1 Code	Requirement	Relevance	Rationale
B006	Prevent unauthorized AI agent actions	Primary	SCOPE
B008	Protect model deployment environment	Primary	ISOLATE



E009	Monitor third-party access	Primary	DETECT
E015	Log model activity	Primary	DETECT
DS003	Restrict unsafe tool calls	Secondary	SCOPE

ASI08 – Cascading Failures

AIUC-1 Code	Requirement	Relevance	Rationale
D001	Prevent hallucinated outputs	Primary	PREV
D002	Third-party testing for hallucinations	Primary	VALID
D003	Restrict unsafe tool calls	Primary	SCOPE
E001	AI failure plan for security breaches	Primary	GOVERN
E002	AI failure plan for harmful outputs	Primary	GOVERN
E003	AI failure plan for hallucinations	Primary	GOVERN
E015	Log model activity	Primary	DETECT
B005	Implement real-time input filtering	Secondary	PREV
B006	Prevent unauthorized AI agent actions	Secondary	SCOPE
C003	Prevent harmful outputs	Secondary	PREV
C007	Flag high risk outputs	Secondary	GATE
C009	Enable real-time feedback and intervention	Secondary	GATE

ASI09 - Human-Agent Trust Exploitation

AIUC-1 Code	Requirement	Relevance	Rationale
C003	Prevent harmful outputs	Primary	PREV
C007	Flag high risk outputs	Primary	GATE
C009	Enable real-time feedback and intervention	Primary	GATE
C010	Third-party testing for harmful outputs	Primary	VALID
D001	Prevent hallucinated outputs	Primary	PREV
D002	Third-party testing for hallucinations	Primary	VALID
E016	Implement AI disclosure mechanisms	Primary	DISCLOSE
A003	Limit AI agent data collection	Secondary	SCOPE
B004	Prevent AI endpoint scraping	Secondary	PREV
B007	Enforce user access privileges to AI systems	Secondary	SCOPE
B009	Limit output over-exposure	Secondary	SCOPE
C005	Prevent customer-defined high risk outputs	Secondary	PREV
C006	Prevent output vulnerabilities	Secondary	PREV
E004	Assign accountability	Secondary	GOVERN
E009	Monitor third-party access	Secondary	DETECT
E015	Log model activity	Secondary	DETECT
E017	Document system transparency policy	Secondary	DISCLOSE

ASII0 – Rogue Agents

AIUC-1 Code	Requirement	Relevance	Rationale
B006	Prevent unauthorized AI agent actions	Primary	SCOPE
B008	Protect model deployment environment	Primary	ISOLATE
D003	Restrict unsafe tool calls	Primary	SCOPE
D004	Third-party testing of tool calls	Primary	VALID
E001	AI failure plan for security breaches	Primary	GOVERN
E015	Log model activity	Primary	DETECT
B003	Manage public release of technical details	Secondary	PREV
B007	Enforce user access privileges to AI systems	Secondary	SCOPE
B009	Limit output over-exposure	Secondary	SCOPE
C007	Flag high risk outputs	Secondary	GATE
C008	Monitor AI risk categories	Secondary	DETECT
C009	Enable real-time feedback and intervention	Secondary	GATE
D002	Third-party testing for hallucinations	Secondary	VALID
E016	Implement AI disclosure mechanisms	Secondary	DISCLOSE
F001	Prevent AI cyber misuse	Secondary	PREV
F002	Prevent catastrophic misuse	Secondary	DETECT



APPENDIX B – Related OWASP Agentic Security Initiative publications

The OWASP Top 10 for Agentic Applications is part of a broader suite of resources from the OWASP GenAI Security Project's Agentic Security Initiative (genai.owasp.org). These companion documents provide deeper technical context for the threats and mitigations referenced in this crosswalk:

- **Agentic AI - Threats and Mitigations v1.1** (February 2025; updated December 2025) - The foundational threat taxonomy underpinning the Top 10. Provides detailed threat models, attack trees, and mitigation strategies for each risk category.
- **Multi-Agentic System Threat Modeling Guide v1.0** (April 2025) - Threat modeling guidance specific to multi-agent architectures. Particularly relevant to ASI07 and ASI10.
- **Agent Name Service (ANS) for Secure AI Agent Discovery v1.0** (May 2025) - A DNS-inspired framework for agent identity and discovery using PKI. Relevant to the AIUC-1 gaps identified under ASI07 and ASI10.
- **Securing Agentic Applications Guide 1.0** (July 2025) - Practical technical guidance for securely designing and deploying LLM-powered agentic applications.
- **State of Agentic AI Security and Governance 1.0** (August 2025) - A governance-focused guide covering frameworks, regulatory standards, and organizational practices for responsible agentic AI deployment.
- **CheatSheet - A Practical Guide for Securely Using Third-Party MCP Servers 1.0** (November 2025) - Focused guidance on securing Model Context Protocol (MCP) server integrations. Particularly relevant to ASI04 and ASI02.
- **A Practical Guide for Secure MCP Server Development** (February 2026) - Developer-focused guidance for building secure MCP servers. Relevant to ASI04 and ASI05.



Acknowledgements

Co-Authors

John Sotiropoulos: Founder & Principal Consultant, Deep Cyber / OWASP GenAI Security Project Agentic Security Initiative Co-Lead

Kyriakos “Rock” Lambros: Director of AI Standards & Governance, Zenity | Founder, RockCyber OWASP GenAI Security Project and Agentic Security Initiative Core Teams

Expert Reviewers (OWASP)

Tomer Elias: Independent

Madjid Nakhjiri: Independent Security Consultant | AI Security

Vineeth Sai Narajala: Senior Technical Leader – AI Security Researcher, Cisco

Expert Reviewers (AIUC-1)

Emil Bender Lassen: Founding Standard Lead, AIUC-1

Abby Shen: AIUC-1

Technical Contributors

Syed Aamiruddin: AI Security Engineer, OWASP Top 10 for Agentic Apps Entry Lead

Kellen Carl: AI Security Engineer

Boone Carlson: AI Governance Architect

Emmanuel Guilherme Jr.: OWASP GenAI Security Project Data Initiative Lead

Violeta Klein CISSP: ISO/IEC 42001 & 27001 Lead Auditor

Rico Komenda: OWASP AISVS Co-Lead

Narendra Kumar

Gaurav Mukherjee, Independent: OWASP Top 10 for Agentic Applications Entry Lead

Roger Sanz: AI Security Researcher

Otto Sulin: OWASP AISVS Co-Lead

OWASP GenAI Security Project Sponsors

We appreciate our Project Sponsors, funding contributions to help support the objectives of the project and help to cover operational and outreach costs augmenting the resources provided by the OWASP.org foundation. The OWASP GenAI Security Project continues to maintain a vendor neutral and unbiased approach. Sponsors do not receive special governance considerations as part of their support.

Sponsors do receive recognition for their contributions in our materials and web properties. All materials the project generates are community developed, driven and released under open source and creative commons licenses. For more information on becoming a sponsor, [visit the Sponsorship Section on our Website](#) to learn more about helping to sustain the project through sponsorship.

Project Sponsors:



Sponsors list, as of publication date. Find the full sponsor [list here](#).



Project Supporters

Project supporters lend their resources and expertise to support the goals of the project.

Accenture	Cobalt	Kainos	PromptArmor
AddValueMachine Inc	Cohere	KLAVAN	Pynt
Aeye Security Lab Inc.	Comcast	Klavan Security Group	Quiq
AI informatics GmbH	Complex Technologies	KPMG Germany FS	Red Hat
AI Village	Credal.ai	Kudelski Security	RHITE
aigos	Databook	Lakera	SAFE Security
Aon	DistributedApps.ai	Lasso Security	Salesforce
Aqua Security	DreadNode	Layerup	SAP
Astra Security	DSI	Legato	Securiti
AVID	EPAM	Linkfire	See-Docs & Thenavigo
AWARE7 GmbH	Exabeam	LLM Guard	ServiceTitan
AWS	EY Italy	LOGIC PLUS	SHI
BBVA	F5	MaibornWolff	Smiling Prophet
Bearer	FedEx	Mend.io	Snyk
BeDisruptive	Forescout	Microsoft	Sourcetoad
Bit79	GE HealthCare	Modus Create	Sprinklr
Blue Yonder	Giskard	Nexus	stackArmor
BroadBand Security, Inc.	GitHub	Nightfall AI	Tietoevry
BuddoBot	Google	Nordic Venture Family	Trellix
Bugcrowd	GuidePoint Security	Normalyze	Trustwave SpiderLabs
Cadea	HackerOne	NuBinary	U Washington
Check Point	HADESS	Palo Alto Networks	University of Illinois
Cisco	IBM	Palosade	VE3
Cloud Security Podcast	iFood	Praetorian	WhyLabs
Cloudflare	IriusRisk	Preamble	Yahoo
Cloudsec.ai	IronCore Labs	Precize	Zenity
Coalfire	IT University Copenhagen	Prompt Security	

Supporters list, as of publication date. Find the full supporter [list here](#).